

Applicability Compliance

**Topic: Network Segmentation Effectiveness for PCI DSS Scope
Reduction**

Name: THY DAYUTH

Contents

Summary of Applicable Requirements	3
Reference	13

Summary of Applicable Requirements

Requirement	Sub ID(s)	Description
Requirement 1 Install and Maintain Network Security Controls	1.2.3	Maintain accurate network diagrams showing all CDE connections.
	1.2.4	Maintain accurate data-flow diagrams for account data.
	1.2.5	Identify and approve all allowed services, protocols, and ports.
	1.2.6	Implement security features for all allowed insecure protocols.
	1.2.8	Secure configuration files from unauthorized access.
	1.3.1	Restrict inbound traffic to the CDE to only what is necessary.
	1.3.2	Restrict outbound traffic from the CDE to only what is necessary.
	1.4.1	Implement NSCs between trusted and untrusted networks.

	1.4.2	Authorized com between trusted and untrusted with stateful response firewall, other denied by default,
	1.4.3	Deploy Anti Spoofing
	1.4.4	Prevent direct access to stored CHD from untrusted networks.
	1.4.5	Limit disclosure of internal IP addresses to authorized parties.
	1.5.1	Device which can be accessed to both CDE and internet must have security controls to prevent tampering or data exfiltration
Requirement 2 Apply Secure Configurations to All System Components	2.2.1	Develop and apply system-hardening standards.
	2.2.2	Change or disable all vendor default passwords and accounts.
	2.2.3	Isolate primary system functions or different security levels.
	2.2.4	Enable only necessary services and remove unnecessary functions.

	2.2.5	Justify and secure any necessary insecure protocols.
	2.2.6	Configure security parameters according to standards.
	2.2.7	Encrypt all non-console remote administrative access.
Requirement 3 Protect Stored Account Data	3.2.1	Data retention, CHD matrix, secure delete data, check every 3 months
	3.3.1	Prohibit storage of Sensitive Authentication Data (SAD) post-auth.
	3.3.2	SAD must be encrypted all time
	3.4.1	Mask PAN when displayed (max BIN and last 4 digits).
	3.4.2	prevent users from copy, download PAN remotely unless authorized
	3.5.1	Render stored PAN unreadable everywhere it is stored.

	3.6.1	Securing key management key integrity
	3.7.1	Use Key management system
	3.7.2	Have procedure for key rotation
	3.7.5	Key destruction
	3.7.6	Split knowledge access control
	3.7.7	key must be protected from being replaced or tampered with by unauthorized sources
Requirement 4 Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks	4.2.1	Encrypt PAN with strong cryptography over public networks.
	4.2.2	Prohibit cleartext PAN in end-user messaging (email/SMS).
Requirement 5 Protect All Systems and Networks from Malicious Software	5.2.1	Deploy anti-malware on all system components.

	5.2.2	Ensure solution detects, blocks, and contains all malware types.
	5.3.1	Configure anti-malware for current automatic updates.
	5.3.2	scan periodic and active or Realtime...
	5.3.3	Automatically scan all removable electronic media.
	5.3.4	Enable anti-malware audit logs and retain them.
	5.3.5	Prevent users from disabling anti-malware mechanisms.
	5.4.1	Implement automated technical protections against phishing.
Requirement 6 Develop and Maintain Secure Systems and Software	6.2.3	Perform pre-release code reviews for all custom software.
	6.2.4	Build software securely to prevent common attacks and vulnerabilities from reaching production

	6.4.1	Protect public-facing web applications from attacks.
	6.4.3	Control and protect all JavaScript loaded on payment pages
	6.5.3	Separate pre-production and production environments.
	6.5.4	separate between pre-prod and prod to track accountability
	6.5.5	Prohibit live PANs in pre-production environments.
	6.5.6	Remove test data/accounts before systems go active.
Requirement 7 Restrict Access to System Components and Cardholder Data by Business Need to Know	7.3.1	Use automated access control systems for all components.
	7.3.2	Configure access systems to enforce job-based permissions.
	7.3.3	Set access control systems to "deny all" by default.

Requirement 8 Identify Users and Authenticate Access to System Components	8.2.1	Assign a unique ID to every user for all access.
	8.2.2	Not using share group ID (accept risk when needs to use)
	8.2.4	add, delete, modification of user ID for authorization
	8.2.5	Immediately revoke access for terminated users.
	8.2.6	Remove or disable inactive user accounts within 90 days.
	8.2.8	Require re-authentication for idle sessions (>15 mins) otherwise log off 1 hour after
	8.3.1	Use at least one strong factor (password/token/biometric).
	8.3.2	Render authentication factors unreadable during transit/storage.
	8.3.3	user must be verified before modify authentication factor

	8.3.4	lock out for not more than 10 attempts, lock for minimum of 30 mins or when user confirmed
	8.3.5	Do not use default password after reset
	8.3.6	password must be strong (8 if 12 not support otherwise 12 as minimum and both numeric and alphabetic)
	8.3.7	Prohibit reuse of the last four passwords.
	8.3.9	single sign password must be changed at least once in 90 days or accept risk
	8.3.10	single sign password in CDE must be changed periodically
	8.4.1	Implement MFA for non-console CDE administrative access.
	8.4.2	Implement MFA for all non-console access to the CDE.
	8.5.1	MFA must be secure, mandatory, and use at least two different authentication factors

	8.6.1	Restrict and justify interactive use of service accounts.
	8.6.2	Prohibit hard coding passwords in scripts or source code.
Requirement 9 Restrict Physical Access to Cardholder Data	N/A	N/A
Requirement 10 Log and Monitor All Access to System Components and Cardholder Data	10.2.1	Enable all logs from components
	10.3.1	Limit log read access to those with a business need
	10.3.2	Protect audit logs from unauthorized modifications.
	10.3.4	FIM to prevent unauthorized modification
	10.4.1	Review logs daily
	10.4.2	review all other system components log periodically

	10.4.3	Address and remediate log exceptions and anomalies.
	10.5.1	Retain logs history 12 months and 3 months prior must be available
	10.6.1	Synchronize all system clocks using NTP technology.
	10.6.2	sync time across all components
Requirement 11 Test Security of Systems and Networks Regularly	11.3.1	Perform internal vulnerability scans every three months.
	11.3.1.2	Conduct internal scans via authenticated scanning.
	11.3.1.3	Perform internal scans after any significant changes.
	11.3.2.1	Perform external scans after any significant changes.
	11.4.5	Validate network segmentation effectiveness annually.

	11.4.6	Validate segmentation bi-annually (Service Providers).
	11.6.1	Detect unauthorized script/header changes on payment pages.
Requirement 12 Support Information Security with Organizational Policies and Programs	12.3.3	Inventory all cryptographic cipher suites and protocols.
	12.5.1	Maintain an inventory of all in-scope system components.
	12.10.1	Maintain a formal incident response plan ready for use.
	12.10.2	Review and test the incident response plan annually.

Reference

https://listings.pcisecuritystandards.org/documents/pci_ssc_quick_guide.pdf¹

https://www.middlebury.edu/sites/default/files/2025-01/PCI-DSS-v4_0_1.pdf?fv=AKHVQBp6²

https://www.pcisecuritystandards.org/document_library/³

¹ PCI-DSS version 1.2: PCI Quick Reference Guide

² PCI-DSS 4.0.1v: Requirements and Testing Procedures

³ PCI SCC Document Library